

PUBLIC PROFESSIONAL BRIEF

SBOM and Vulnerability Management Brief

Software component visibility, vulnerability scan interpretation, and KEV/EPSS-based remediation prioritization for NorthGrid Energy.

Prepared by	Bernard Boakye Appiah
Scenario organization	NorthGrid Energy - fictional Ontario critical infrastructure operator
Document type	SBOM and vulnerability brief
Public disclosure	All content is sanitized and based on a fictional security assessment scenario.
Date	July 2026

Selected assessment metrics

2,393 SBOM components	119 CVEs found	KEV + EPSS + reachability Prioritization
---------------------------------	--------------------------	--

Public disclosure note: NorthGrid Energy is a fictional scenario used to demonstrate professional cybersecurity assessment, governance, and risk communication skills. The content is sanitized for public review and does not contain proprietary or private operational data.

OVERVIEW

Purpose and Executive Summary

This brief presents the software bill of materials and vulnerability management portion of the NorthGrid Energy assessment. It demonstrates how component visibility, vulnerability scanning, KEV/EPSS prioritization, and OT-safe remediation planning can support a critical infrastructure security program.

The SBOM workflow showed that even a standard Ubuntu 22.04 image can contain thousands of components and many vulnerability records. For an EMS, historian, or vendor-managed OT application, this reinforces why supplier SBOMs and component-level vulnerability review are essential.

CycloneDX 1.6 SBOM format	2,393 Components catalogued	Syft + Gripe Scanner
119 Total CVEs	1 High severity	66 Medium severity

METHOD

SBOM Workflow

Step	Professional purpose	NorthGrid value
Generate SBOM	Create a machine-readable inventory of packages and dependencies.	Shows what exists below the visible application layer.
Scan SBOM	Compare components against vulnerability intelligence.	Identifies vulnerable libraries without relying only on product names.
Cross-reference KEV	Check whether findings are known to be actively exploited.	Raises priority when exploitation is confirmed in the wild.
Use EPSS and reachability	Estimate likelihood and operational exposure.	Prevents over-prioritizing low-risk issues while ignoring reachable exploitable services.
Apply OT-safe remediation	Validate patches with vendors and maintenance windows.	Protects availability and safety while still reducing risk.

EVIDENCE SUMMARY

Gripe Vulnerability Summary

Severity	Count	Public interpretation
Critical	0	No critical findings were recorded in this scan output.
High	1	One high-severity vulnerability required priority review.
Medium	66	Medium findings form the bulk of remediation planning and patch-cycle work.
Low	44	Low findings require tracking but may not justify emergency action alone.
Negligible	8	Low operational priority unless paired with exposure or exploit evidence.
Unknown	0	No unknown-severity findings were recorded.
Total	119	The scan demonstrates why component visibility matters for software risk management.

VULNERABILITY EXAMPLES

Representative High-Priority Findings

The table below is a public summary of representative vulnerability records from the scan. It avoids presenting raw scan output as the main deliverable and instead explains why the findings matter for risk decisions.

CVE	Package	Installed version	Fixed version	Reason for review
CVE-2026-45447	libssl3	3.0.2-0ubuntu1.23	3.0.2-0ubuntu1.25	High severity in a widely used cryptographic library.
CVE-2026-42012	libgnutls30	3.7.3-4ubuntu1.8	3.7.3-4ubuntu1.9	TLS library dependency requiring patch-cycle review.
CVE-2026-45445	libssl3	3.0.2-0ubuntu1.23	3.0.2-0ubuntu1.25	Cryptographic package with available fix.
CVE-2026-5928	libc-bin	2.35-0ubuntu3.13	No fixed version listed	Core OS component; requires vendor/package maintainer guidance.
CVE-2026-5928	libc6	2.35-0ubuntu3.13	No fixed version listed	Core library risk should be validated before operational remediation.

PRIORITIZATION

KEV, EPSS, and Asset Reachability Prioritization

The assessment intentionally avoided relying on CVSS alone. CVSS describes technical severity, but it does not confirm that NorthGrid owns the vulnerable asset, that the asset is reachable, or that attackers are actively exploiting the issue.

Priority input	Question answered	Why it matters
Asset confirmation	Does NorthGrid actually have the affected product or component?	Prevents wasting time on technologies that are not deployed.
Reachability	Can an attacker reach the vulnerable service or trigger path?	Raises urgency for exposed VPN, web, or remote access systems.
CISA KEV	Is the vulnerability known to be exploited?	Moves actively exploited vulnerabilities ahead of theoretical ones.
EPSS	How likely is exploitation in the near term?	Supports probability-aware prioritization.
CVSS	How technically severe is the vulnerability?	Useful but not enough by itself for operational triage.
OT safety	Can the fix be applied safely without disrupting operations?	Controls must reduce risk without creating avoidable outages.

RISK QUEUE

NorthGrid Prioritization Examples

CVE	Decision	Reason
CVE-2024-3400	P1	Confirmed Palo Alto VPN gateway, externally reachable, KEV-listed, and high EPSS.
CVE-2023-36884	P1	Windows workstations confirmed and user-driven phishing/file path makes exposure realistic.
CVE-2021-44228	P1 pending verification	Log4Shell risk cannot be ruled out until EMS SBOM/vendor evidence is available.
CVE-2023-44487	P2	Apache web servers confirmed and reachable, but not KEV and lower EPSS in the assessment context.
CVE-2017-0144	P2	SMBv1/EternalBlue risk requires verification and compensating controls due to flat IT/OT concerns.

OPERATIONAL SAFETY

OT-Safe SBOM and Remediation Approach

For a vendor-managed EMS, the recommended process is not to run aggressive production scans blindly. The safer process is to request a signed, version-specific SBOM from the vendor, validate affected components, compare findings against CISA KEV, EPSS, NVD, and vendor advisories, then schedule remediation through approved OT change control.

- 1 Request a current SBOM for the exact deployed EMS version, including Java libraries, web modules, database connectors, bundled vendor software, and Windows dependencies.
- 2 Validate Log4Shell and other component risks using vendor-approved methods or a staging environment.
- 3 Apply patches during an OT maintenance window when safe and certified by the vendor.
- 4 Use compensating controls when patching is delayed: segmentation, egress restriction, application allowlisting, enhanced logging, and vendor-approved configuration changes.
- 5 Document temporary risk acceptance with an owner, expiry date, monitoring requirement, and target remediation date.

RECOMMENDATIONS

Recommendations

- 1 Add SBOM requirements and vulnerability disclosure expectations to critical vendor contracts.
- 2 Adopt a vulnerability triage model that combines KEV, EPSS, CVSS, asset ownership, reachability, and business impact.
- 3 Treat unknown component visibility in OT as a risk condition that requires verification, not as a reason to ignore the issue.
- 4 Create an OT-safe patch workflow with vendor validation, maintenance windows, rollback planning, and compensating controls.
- 5 Report vulnerability work in business terms: affected asset, exploitability, potential operational impact, owner, due date, and control status.